

OPERATION IRON RAVEN

Lessons-Learned Reflective Statement

Student	Daniyal Ahmed
Registration	C11/26/EHIT/17331
Course	Offensive Security Operations II — CIP-A105
Date	16 September 2026
Classification	Training Use Only

1. Operational Outcome

Operation Iron Raven concluded with 100% mission success. All four flags were recovered, full root-level OS compromise was demonstrated, and every action was documented with timestamped, evidence-referenced entries. The complete attack chain — from unauthenticated web enumeration through remote code execution, credential harvesting, and MySQL UDF privilege escalation to root — was achieved in a single session of approximately six hours without any external hints or walkthroughs.

2. Key Technical Insights

- **Enumeration depth is decisive:** The single most impactful discovery of the engagement was the `/vendor/VERSION` file. Identifying PHPMailer 5.2.16 reduced an open-ended exploitation search to a single targeted, high-confidence vector in under ten minutes. Methodical enumeration of every accessible URI — not just the application root — was the determining factor.
- **Compounding misconfigurations amplify risk non-linearly:** Neither the PHPMailer RCE alone, nor the MySQL root misconfiguration alone, would have enabled root compromise independently. Together they formed an attack chain far more severe than any individual vulnerability. This illustrates why configuration hygiene matters as much as patch management.
- **Staging infrastructure must be verified before triggering remote actions:** Three consecutive failed wget attempts (E-034) before the Python HTTP server was running on

Kali were avoidable operational errors. A pre-flight checklist verifying all attacker-side services are running before any exploit payload is triggered would eliminate this class of error.

- **Target environment profiling is a first step on foothold:** Running python3 on the target returned 'python3: not found' (E-040) because Debian Jessie ships Python 2.7 by default. Immediately running cat /etc/os-release and python --version upon initial access — before any further commands — is now a fixed first step in post-exploitation procedure.

3. Documented Failed Hypotheses

The following seven approaches were tested and explicitly falsified. Transparent documentation of failed hypotheses demonstrates systematic methodology and evidence-based reasoning:

- WordPress wp_posts query for '%flag%' keyword — returned empty set (0 rows). Hypothesis falsified.
- MySQL wp_users description column query — Error 1054: column does not exist. Hypothesis falsified.
- SSH direct login as 'steven' with candidate passwords — Permission denied. Abandoned to avoid lockout.
- su steven inside www-data shell with candidate passwords — Authentication failure x2.
- wget 1518.so before Python HTTP server was running — Connection refused x3. Procedural error.
- python3 invocation on target — python3: not found. Target runs Python 2.7 (Debian Jessie).
- Web shell write to /var/www/html/shell.php and /var/www/shell.php — POST failed / timeout.

4. Improvements for Future Operations

- **Pre-flight checklist:** Before executing any exploit or file-transfer command, verify all attacker-side services (HTTP servers, listeners, staging directories) are fully operational.
- **Immediate environment profiling:** On first foothold, run: cat /etc/os-release, uname -a, id, python --version, python3 --version, and ls /usr/bin/python* to profile the target runtime before any further post-exploitation commands.
- **Live evidence sequencing:** Assign E-IDs to screenshots in real time during the operation rather than retrospectively, to maintain a complete and gapless evidence chain.
- **PTY spawning before credential attacks:** Always spawn a full interactive PTY using python -c 'import pty; pty.spawn("/bin/bash")' before attempting su, passwd, or any command that requires a controlling terminal.

- **Scope confirmation on each phase transition:** Before moving from one phase to the next, confirm all actions remain within the authorised scope and document the transition decision.

5. Personal Development Statement

This engagement substantially advanced my proficiency in three areas: executing a complete phased penetration test methodology from reconnaissance through to post-exploitation reporting; identifying and weaponising a real-world CVE (CVE-2016-10033) from a version-pinned component disclosure; and applying the MySQL UDF SUID escalation technique to translate database administrative access into OS root control. The experience of encountering, documenting, and analytically disposing of seven false hypotheses was equally instructive, reinforcing that professional security work demands transparent, evidence-based reasoning at every step — not success-only reporting.

Student Signature:	Daniyal
Date:	16 September 2026